URL-only phishing classifier: report

Every number comes from reports/*.json. Definitions and extra detail are in the README.

This report is available as a .md file under /reports.

1. The result I would tell my manager

Metric I stand behind: recall at 1 % false-positive rate (FPR) in 5-fold cross-validation grouped by registered domain, so no website is on both sides of a split. Thresholds were fixed on this validation before either test file was read.

Advanced model	n	ROC-AUC [95% CI]	Recall [95 % CI]	FPR (false positives)	Baseline AUC / recall
Validation (grouped CV)	8,319	0.975	0.702	0.99 % (42)	0.963 / 0.670
test.csv	2,858	0.987 [0.982, 0.991]	0.795 [0.773, 0.816]	0.63 % (9)	0.979 / 0.755
↳ domain not in train	1,665	0.975	0.688	0.70 % (7)	–
external_test.csv	2,858	0.907 [0.894, 0.919]	0.458 [0.432, 0.484]	0 % (0)	0.944 / 0.368

Claim: for new domains from similar feeds, the model catches about **70 % of phishing while flagging about 1 % of legitimate URLs**. At 1 phishing URL in 1,000, only **about 7–11 % of alerts would be real**. On differently collected data, recall falls to **46 %**.

- **test.csv is optimistic:** 41.8 % of its rows share a registered domain with train, and recall is 0.889 on those versus 0.688 on unseen domains.
- **external_test.csv is shifted but unrealistic:** only 2.4 % of its domains appear in train. However, *all* of its legitimate URLs are bare homepages, against 37 % in train, so 0 false positives says little about real traffic.
- **The advanced model is worse on external AUC** (0.907 vs 0.944): it scores 30 % of external phishing below 0.05 (baseline: 4 %). *Untested hypothesis:* the trees learned "bare host = legitimate".

2. URL characteristics (legitimate vs phishing)

1. **Host structure is the most stable signal.** A digit in the host: 3.2 % vs 22.8 % in train, 2.6 % vs 36.5 % in external. Three or more host labels: 28.5 % vs 57.9 %, and 15.0 % vs 56.3 %. The direction holds in two independent collections. That is evidence it generalises, not proof.
2. **URL format mostly reflects how each dataset was built.** A path or query appears in 62.6 % vs 81.5 % of train URLs, but 0 % vs 28.8 % of external ones. These are dataset patterns, not facts about phishing.
3. **Weakened hypothesis: "credential and brand words identify phishing."** Words like login / verify / account appear in 23.6 % of train phishing vs 0.9 % of legitimate URLs, but in only **6.4 %** of external phishing. They describe phishing-kit URLs in these feeds, not phishing in general.

3. Threshold and deployment (prevalence $\pi = 0.001$)

Threshold: set just above the 43rd-highest out-of-fold score of the 4,257 legitimate training URLs, so at most 1 % (42) are flagged. That gives **0.971**, which is used unchanged on both test sets and in predict().

Deployed precision = $\mathrm{TPR}\cdot\pi / (\mathrm{TPR}\cdot\pi + \mathrm{FPR}\cdot(1-\pi))$. This assumes the measured rates carry over to real traffic and that the labels are correct.

Advanced model	Recall	FPR	Deployed precision
Validation at 0.971 (**chosen**)	0.702	0.99 %	6.7 %
Validation at 0.9994 (0.1 % FPR)	0.344	0.09 % (4 false positives)	27 %
test.csv / unseen domains	0.795 / 0.688	0.63 % / 0.70 %	11 % [6–22] / 9 % [4–20]

Per million URLs, this means about 700 phishing URLs caught, 300 missed, and 9,900 legitimate URLs flagged.

Sample size: the 0.1 % point rests on only 4 false positives, which is too few to rely on. With 1,429 legitimate URLs per test set, even zero false positives allows an FPR of up to 0.26 %, i.e. a precision of anywhere from 14 % to 100 %.

Decision: use the score to **prioritise a review queue** or run it in shadow mode; defer warning and blocking. Evidence needed first: labelled, time-ordered real traffic with at least 30,000 legitimate URLs, validation that holds out whole phishing campaigns, interaction with existing allow / block lists, and a calibration fitted on that traffic.

4. Data handling

The 8,651 training rows contain:

- 30 exact duplicates and 282 duplicates after normalisation;
- 50 URLs labelled both ways (107 rows);
- 185 rows with HTML entities (&), all phishing, which is a scraping artefact;
- 2,268 rows with upper case and 20 over 500 characters;
- heavy concentration, e.g. 265 rows on duilawyeryork.com.

Rules:

1. One cleaning function, also used by predict(): HTML-unescape, drop control characters, lowercase, whitespace → %20, cap at 2,048 characters (changes the 2,268 upper-case and 185 HTML-entity rows).
2. Drop normalised URLs with conflicting labels (107 rows).
3. Keep one row per normalised URL (225 rows removed, after the 107 conflicting rows were dropped).

This leaves 8,319 rows (4,062 phishing / 4,257 legitimate). Mixed-label hosts are kept, because legitimate platforms do host phishing. An alternative is to keep conflicting URLs with a majority label; I dropped them, because a URL labelled both ways gives no reliable target.

5. Decisions (observation → action → effect)

1. **Observation:** 42 % of test rows share a domain with train. → **Action:** grouped CV for all selection and thresholds. → **Effect:** the baseline reads 0.963 AUC / 67 % recall, not an optimistic 0.973 / 74 % with random folds. That is close to its unseen-domain test result (0.961 / 63 %).
2. **Observation:** conflicting labels and duplicates. → **Action:** the cleaning rules above. → **Effect:** baseline CV went from 0.956 / 60 % to 0.963 / 67 %. The row sets differ, so this is not strictly like-for-like.
3. **Observation:** the stable signal is in the host. → **Action:** separate host and path n-grams, word tokens and 22 structure features. Then a small auto-ML sweep over logistic regression, LightGBM, XGBoost and 12 weighted blends, selected by validation recall at 1 % FPR. → **Effect:** no single model clearly beat the baseline (0.663 / 0.689 / 0.635 vs 0.670). The blend 0.75 LightGBM + 0.25 LR reached **0.702**, because the two models miss different phishing URLs.
   XGBoost duplicated LightGBM (rank correlation 0.98) and got weight 0.
4. **Unsuccessful. Observation:** the selected blend has a lower external AUC than the baseline (0.907 vs 0.944). → **Action:** kept the validation-based selection instead of tuning on external, which would leak the test set into training. → **Effect:** an honest, but weaker, external ranking, listed as a limitation.

6. Limitations and next steps

- **No time split:** real-world performance is probably lower than every number here.
- **URL only:** the model is blind to brand-free phishing on hosting platforms (web.app, repl.co) and easy to evade. It has no content, DNS or domain-age signals.
- **Optimistic validation:** the blend weights and the threshold were chosen on the same out-of-fold scores, and the FPR intervals ignore domain clustering.
- **Not done:** extra training data, campaign-level grouping, calibration on held-out data, and a test of the bare-domain hypothesis.